

Controls and Compliance Checklist - Botium Toys Security Audit

Controls Assessment Checklist

Control	Status
Least Privilege	No
Disaster recovery plans	No
Password policies	No
Separation of duties	No
Firewall	Yes
Intrusion detection system (IDS)	No
Backups	No
Antivirus software	Yes
Manual monitoring, maintenance, and intervention for legacy systems	No
Encryption	No
Password management system	No
Physical locks (offices, storefront, warehouse)	Yes
CCTV surveillance	Yes
Fire detection/prevention	Yes

Compliance Checklist

PCI DSS (payment Card Industry Data Security Standard)

Only authorized users have access to customers' credit card information	No
Credit card information is stored/processed in a secure environment	No
Implement data encryption procedures	No
Adopt secure password management policies	No

GDPR (General Data Protection Regulation)

E.U. customers' data is kept private/secured	Partial
There is a plan to notify E.U. customers within 72 hours in case of breach	Yes
Ensure data is properly classified and inventoried	No
Enforce privacy policies and procedures	Yes

SOC (System and Organizations Controls)

User access policies are established	Partial
Sensitive data (PII/SPII) is confidential/private	No
Data integrity ensures the data is consistent, complete, and validated	Yes
Data is available to individuals authorized to access it	Yes